

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Calificación de 21 Métricas GQM según los 9 Criterios PRAGMATIC

Marco LINDDUN/LIINE4DU • España 2025–2026 • Versión 1.0

"La diferencia entre una métrica con PRAGMATIC 9.0 y una con PRAGMATIC 4.0 no es de grado, es de naturaleza: la primera informa; la segunda, entretiene. Y el coste de ambas suele ser el mismo."

INSTRUCCIONES DE EVALUACIÓN

Cada métrica se evalúa en los 9 criterios PRAGMATIC en escala **0–10** (siendo 0 = no cumple el criterio en absoluto y 10 = lo cumple perfectamente). La puntuación final es la **media aritmética** de los 9 criterios.

Umbrales de calidad:

- **≥ 8.0** →  **Excelente:** incorporar al cuadro de mando prioritariamente
- **≥ 6.5** →  **Buena:** incorporar al cuadro de mando
- **≥ 5.0** →  **Aceptable:** incorporar solo si no hay alternativa mejor; plan de mejora
- **< 5.0** →  **Revisar:** rediseñar o sustituir antes de incorporar

Criterios clave a entender:

- **P (Predictivo):** puntuación alta si la métrica permite actuar ANTES del incumplimiento; baja si solo confirma lo que ya ha ocurrido
- **G (Genuino):** puntuación alta si la métrica mide directamente el fenómeno; baja si es un proxy indirecto con riesgo de Goodhart's Law
- **I (Independiente):** puntuación alta si el sujeto medido NO puede manipular el resultado fácilmente; baja si puede "inflar" el número

TABLA MAESTRA — PUNTUACIONES PRAGMATIC POR MÉTRICA

Métrica	P	R	A	G	M	A	T	I	C	Total	Nivel
L-M1 % DFDs actual izados	5	8	9	7	8	7	6	7	10	7.44	★★ Buena
L-M2 Quasi- identificados no controlados	7	9	9	7	7	7	6	7	8	7.44	★★ Buena
L-M3 ICAV (Índice Controles Anti- Vinculación)	7	8	8	6	7	7	6	8	8	7.22	★★ Buena
L-M4 TTDL (horas detección vinculación)	6	9	9	8	8	8	9	8	7	8.00	★★★ Excelente

L-M5 % mode los ML con EIPD linkin g	5	10	10	9	9	9	8	8	8	8.44	★★★ Excel ente
I-M1 K- anoni mato datas ets public ados	6	9	8	9	7	9	8	9	6	7.89	★★★ Buen a
I-M2 % datas ets con análisis re- identi f.	5	9	9	8	8	8	7	8	9	7.89	★★★ Buen a
I-M3 FAR (False Accep tance Rate) biom étrica	9	10	9	8	7	9	8	9	6	8.33	★★★ Excel ente
I-M4 % siste mas biom étrico s con EIPD	4	10	10	9	9	9	8	8	8	8.33	★★★ Excel ente

I-M5 Epsilon (ε) privacidad diferencial	9	9	7	8	5	9	8	9	5	7.67	★★ Buena
NR-M1 Competitividad logs acceso	6	9	8	8	8	9	9	8	9	8.22	★★★ Excelente
NR-M2 Desviación retención logs vs. política	5	8	8	8	8	8	7	8	10	7.78	★★★ Buena
NR-M3 % supresiones IA en ≤ 30 días	4	9	10	9	9	8	9	9	8	8.33	★★★ Excelente
NR-M4 TMRS (días supresión)	7	9	9	9	9	8	9	8	9	8.56	★★★ Excelente

NR-M5 % conse- ntimi- entos con firma eIDAS	4	8	8	7	8	8	8	9	9	7.67	★★ Buen a
D-M1 IPV video viglia- ncia	5	10	10	8	9	9	8	8	9	8.44	★★★ Excel ente
D-M2 % cáma- ras con EIPD válida	4	10	10	9	9	9	8	8	9	8.44	★★★ Excel ente
D-M3 Inven- tario IoT con eval. privac- idad	6	9	9	7	8	8	7	8	9	7.89	★★ Buen a
D-M4 Vulne- rabili- dades side- chann- el	8	8	9	7	7	8	7	9	8	7.89	★★ Buen a

D-M5 % empl eados infor mado s monit orizac ión	5	10	10	8	9	9	8	8	9	8.44	★★★★ Excel ente
DD- M1 % encar gados con DPA vigen te	7	10	10	8	9	9	8	8	7	8.44	★★★★ Excel ente
DD- M2 % transf . intern acion ales con garan tía	5	10	10	8	9	9	8	8	9	8.44	★★★★ Excel ente
DD- M3 % prom pts IA con datos perso nales	9	10	10	8	9	9	8	8	7	8.67	★★★★ Excel ente
DD- M4 % herra mient as IAgen con EIPD	5	10	10	9	9	9	8	8	8	8.44	★★★★ Excel ente

DD-M5 IMD (Índice Minimización Datos)	7	8	8	7	8	7	6	7	9	7.44	★★ Buena
U-M1 ILPP (legibilidad política privacidad)	4	8	9	8	9	8	8	7	9	7.78	★★ Buena
U-M2 % ARCO + atendidos en ≤ 30 días	5	9	10	9	9	9	9	8	9	8.56	★★★ Excelente
U-M3 % consentimientos válidos (4 requisitos)	7	10	10	8	9	9	8	8	7	8.44	★★★ Excelente
U-M4 % decisiones autom. con explicación	5	10	10	8	9	8	8	8	8	8.22	★★★ Excelente

U-M5 % empl eados forma dos en privac idad	4	8	9	8	9	8	9	7	9	7.89	★★ Buen a
NC- M1 IMC (Índic e Madu rez Cump limie nto)	5	9	8	7	9	8	7	7	9	7.67	★★ Buen a
NC- M2 % trata mient os alto riesgo con EIPD	4	10	10	9	10	9	9	9	9	8.78	★★★ Excel ente
NC- M3 Tasa brech as notifi cadas ≤ 72h	5	10	10	9	10	9	10	9	9	9.00	★★★ Excel ente

NC-M4 TMNB (tiempo notificación brechas)	7	9	9	9	9	8	10	9	9	8.78	★★★★ Excelente
NC-M5 IPAA (Índice Preparación AI Act)	5	10	10	9	10	9	9	8	8	8.67	★★★★ Excelente
IN-M1 Tasa registros con verif. exactitud	5	8	8	7	8	8	7	8	9	7.56	★★★★ Buena
IN-M2 TMRR (tiempo resolución rectificación)	4	8	9	8	9	8	9	8	9	8.00	★★★★ Excelente

IN-M3 DIR (Disparate Impact Ratio)	9	9	8	8	6	8	7	8	6	7.67	★★ Buena
IN-M4 % modelos alto riesgo con auditoría sesgo	5	9	9	8	8	8	8	9	8	8.00	★★★ Excelente
EX-M1 Conformidad WCA G 2.1 AA	5	8	9	8	8	9	8	8	9	8.00	★★★ Excelente
EX-M2 Formatos accesibles disponibles	4	7	8	7	7	8	7	8	9	7.22	★★ Buena
EX-M3 Canales no digitales ejercicio derechos	4	8	9	8	7	8	7	8	9	7.56	★★ Buena

RANKING PRAGMATIC — TOP 10 MÉTRICAS

Rango	Métrica	Puntuación	Nivel	Indicador
1	NC-M3 (Brechas ≤72h)	9.00	★★★★	NC
2	NC-M2 (EIPDs alto riesgo)	8.78	★★★★	NC
2	NC-M4 (TMNB)	8.78	★★★★	NC
4	DD-M3 (Prompts IA)	8.67	★★★★	DD
4	NC-M5 (IPAA)	8.67	★★★★	NC
6	NR-M4 (TMRS)	8.56	★★★★	NR
6	U-M2 (ARCO+)	8.56	★★★★	U
8	L-M5 (EIPDs ML)	8.44	★★★★	L
8	D-M1 (IPV videovigilancia)	8.44	★★★★	D
8	D-M2 (EIPDs CCTV)	8.44	★★★★	D

Nota: Comparten posición 8 con PRAGMATIC=8.44: también D-M5, DD-M1, DD-M2, DD-M4, NR-M3, I-M3, I-M4, U-M3.

ANÁLISIS DE BRECHAS POR CRITERIO PRAGMATIC

Puntuaciones Medias por Criterio (todo el catálogo):

Criterio	Media	Rango	Fortaleza/Debilidad
R — Relevante	9.05	7–10	👊 Fortaleza estructural del catálogo
A — Accionable	9.07	7–10	👊 Fortaleza estructural del catálogo
I — Independiente	8.12	7–9	✅ Sólido
G — Genuino	8.00	6–9	✅ Sólido
M — Meaningful	8.33	5–10	✅ Sólido (con excepciones técnicas)
A(cc) — Accurate	8.40	7–9	✅ Sólido
T — Timely	7.93	6–10	✅ Aceptable
C — Cheap	8.33	5–10	✅ Sólido (con excepciones)
P — Predictivo	5.69	4–9	⚠️ DEBILIDAD SISTÉMICA

Análisis del Criterio P (Predictivo) — La Oportunidad de Mejora

El criterio más débil del catálogo es el **Predictivo**, con una media de 5.69. Esta debilidad sistémica no es un defecto del diseño de las métricas sino una consecuencia estructural del campo de medición: la mayoría de las métricas de privacidad miden el **estado actual** o el **rendimiento pasado** (porcentajes de cumplimiento, tiempos de respuesta medidos a posteriori), no el **riesgo futuro**.

Las excepciones son reveladoras:

- **IN-M3 (DIR = 9)**: el DIR es predictivo porque detecta sesgos antes de que causen daño a individuos concretos
- **I-M5 ($\epsilon = 9$)**: el epsilon de privacidad diferencial es inherentemente predictivo del riesgo de re-identificación
- **D-M4 (vulnerabilidades side-channel = 8)**: detecta vectores de ataque antes de que sean explotados

Recomendación: Para mejorar la capacidad predictiva del sistema de medición, añadir indicadores adelantados (*leading indicators*) al cuadro de mando:

- Número de nuevos sistemas de IA desplegados sin EIPD (L-M5, I-M4: leading indicator)
- Número de proveedores TI sin DPA que han accedido a datos en los últimos 30 días (DD-M1: leading indicator)
- Volumen de datos personales en sistemas sin clasificar (L-M2: leading indicator)

ANÁLISIS DETALLADO POR MÉTRICA — NOTAS DE EVALUACIÓN

NC-M3 — Tasa de Brechas Notificadas $\leq 72h$ (PRAGMATIC: 9.00 ★★★★★)

La métrica estrella del catálogo es casi perfecta desde el punto de vista PRAGMATIC:

- **P=5**: Solo penaliza el predictivo porque mide el cumplimiento pasado, no el riesgo de brecha futuro.

Una brecha tiene que ocurrir para que la métrica funcione.

- **R=10**: Sin discusión posible. Art. 33 RGPD es una obligación legal directa con sanción.
- **A=10**: La acción es inequívoca: si TMNB > 72h, el proceso de notificación está roto y hay que arreglarlo inmediatamente.
- **G=10**: La métrica mide exactamente lo que dice: el porcentaje de brechas notificadas en el plazo legal.
- **M=10**: Comprensible para cualquier directivo: "el 80% de nuestras brechas se notifica en ≤ 72 horas" no requiere traducción.
- **I=9**: Difícil de manipular: los timestamps de notificación a la AEPD quedan registrados en el portal oficial. Solo puede manipularse retrasando el "conocimiento" de la brecha, lo que configura otra infracción.
- **T=10**: El plazo de 72 horas implica por definición que la métrica debe estar disponible en tiempo real.
- **C=9**: Una vez implementado el proceso de gestión de incidentes, el coste marginal de medir esta métrica es mínimo.

Criterio más débil: P (Predictivo). **Solución:** añadir NC-M3_lead = "número de simulacros de brecha realizados en los últimos 12 meses" como indicador complementario.

NC-M2 — % Tratamientos Alto Riesgo con EIPD (PRAGMATIC: 8.78 ★★★★★)

- P=4: El mayor punto débil: la métrica solo detecta la ausencia de EIPD cuando ya se está tratando datos (después del hecho). El caso AENA demuestra que una organización puede tener esta métrica en 0% durante años sin notarlo si no la mide activamente.
- R=10: RGPD Art. 35 sin margen de interpretación. Obligación directa.
- M=10: "Solo el X% de nuestros tratamientos de alto riesgo tienen EIPD" es devastadoramente claro.
- I=9: Una EIPD puede ser de mala calidad (cumplimiento formal sin sustancia), pero su existencia es binaria y verificable por un auditor externo.

Criterio más débil: P (Predictivo). **Solución:** añadir NC-M2_lead = "número de nuevos proyectos de alto riesgo iniciados sin haber solicitado EIPD al DPO" como KPI de proceso.

I-M5 — Epsilon (ϵ) de Privacidad Diferencial (PRAGMATIC: 7.67 ★★)

- P=9: El único indicador con alta puntuación predictiva del indicador I. Un ϵ elevado anticipa el riesgo de re-identificación antes de que un atacante lo explote.
- M=5: El punto más débil. "Nuestro epsilon es 3.7" es opaco para cualquier directivo. Solución: traducir siempre a lenguaje de negocio: "Con $\epsilon=3.7$, el riesgo adicional de re-identificación que asumimos es X veces superior al de $\epsilon=1$."
- C=5: El cálculo del epsilon y el mantenimiento del presupuesto de privacidad diferencial tiene un coste computacional relevante en modelos grandes. Justificado solo cuando el riesgo de re-identificación es significativo (datos de salud, biométricos, etc.).

DD-M3 — % Prompts con Datos Personales (PRAGMATIC: 8.67 ★★★★★)

- P=9: La métrica más predictiva del indicador DD. Un aumento en la tasa de prompts con datos personales precede a un incidente de divulgación, no lo sigue.
- A=10: La acción es clara: por encima del umbral del 2%, se activan los controles de DLP, la formación de emergencia y la revisión de las políticas de uso de IA generativa.
- C=7: Requiere implementar una solución DLP o un proxy de IA generativa con análisis de contenido, lo que tiene un coste no trivial. Pero el coste es amortizable en otros casos de uso de seguridad de datos.

L-M3 — ICAV — Índice Controles Anti-Vinculación (PRAGMATIC: 7.22 ★★)

- G=6: El punto más débil. El ICAV es una evaluación compuesta de controles; su capacidad de reflejar el riesgo real de vinculación depende de la calidad de la lista de controles evaluados. Si la lista está desactualizada o es incompleta, el ICAV puede ser alto mientras el riesgo real es elevado. Riesgo de Goodhart's Law.
- Recomendación: complementar el ICAV con pruebas de penetración periódicas de re-identificación (L-M2) para validar que los controles realmente funcionan.

MÉTRICAS POR NIVEL DE CALIDAD PRAGMATIC — TABLA RESUMEN

★★★★ Excelentes (PRAGMATIC ≥ 8.0) — 21 métricas

NC-M3 (9.00) · NC-M2 (8.78) · NC-M4 (8.78) · DD-M3 (8.67) · NC-M5 (8.67) · NR-M4 (8.56) · U-M2 (8.56) · L-M5 (8.44) · D-M1 (8.44) · D-M2 (8.44) · D-M5 (8.44) · DD-M1 (8.44) · DD-M2 (8.44) · DD-M4 (8.44) · I-M3 (8.33) · I-M4 (8.33) · NR-M3 (8.33) · U-M3 (8.44) · NR-M1 (8.22) · U-M4 (8.22) · IN-M2 (8.00) · IN-M4 (8.00) · EX-M1 (8.00) · L-M4 (8.00)

★★★ Buenas ($6.5 \leq \text{PRAGMATIC} < 8.0$) — 18 métricas

U-M1 (7.78) · NR-M2 (7.78) · I-M1 (7.89) · I-M2 (7.89) · D-M3 (7.89) · D-M4 (7.89) · U-M5 (7.89) · NC-M1 (7.67) · I-M5 (7.67) · NR-M5 (7.67) · IN-M3 (7.67) · L-M1 (7.44) · L-M2 (7.44) · DD-M5 (7.44) · IN-M1 (7.56) · EX-M3 (7.56) · L-M3 (7.22) · EX-M2 (7.22)

★ Aceptables / ✗ Revisar (< 6.5) — 0 métricas

Ninguna métrica del catálogo está por debajo del umbral de aceptabilidad. El catálogo completo supera el nivel de calidad "Buena" en todos sus ítems. Esta es una característica de diseño deliberada: las métricas han sido seleccionadas y formuladas para maximizar su utilidad operativa, descartando durante el diseño las métricas candidatas con puntuaciones bajas en criterios clave como Genuino, Accionable e Independiente.

ANÁLISIS DE COHERENCIA INTERNA — CORRELACIONES PRAGMATIC

Correlaciones positivas observadas en el catálogo:

- $R \rightarrow A$: Las métricas altamente relevantes desde el punto de vista normativo son también muy accionables ($r \approx +0.85$). Cuando una norma impone una obligación clara y sancionable, tanto la relevancia como la accionabilidad son máximas.
- $G \rightarrow I$: Las métricas que miden directamente el fenómeno (no proxies) son también más difíciles de manipular. Un timestamp de notificación a la AEPD (NC-M3) es más genuino y más independiente que una autoevaluación de cumplimiento.

R $\rightarrow$ A: Las métricas altamente relevantes desde el punto de vista normativo son también muy accionables ($r \approx +0.85$). Cuando una norma impone una obligación clara y sancionable, tanto la relevancia como la accionabilidad son máximas.

G $\rightarrow$ I: Las métricas que miden directamente el fenómeno (no proxies) son también más difíciles de manipular. Un timestamp de notificación a la AEPD (NC-M3) es más genuino y más independiente que una autoevaluación de cumplimiento.

Tensiones detectadas (trade-offs a gestionar):

- **P $\leftrightarrow$ C:** Las pocas métricas con alta capacidad predictiva (ϵ , DIR, D-M4) son las más costosas de recoger (modelos ML, pentesting, análisis de equidad). El cuadro de mando debe incluir al menos 2–3 métricas predictivas de alta calidad para no ser exclusivamente reactivo, aunque su coste sea mayor.
 - **M $\leftrightarrow$ G:** Las métricas más técnicamente precisas (ϵ de privacidad diferencial, FAR biométrica) son las menos comprensibles para directivos no técnicos. Solución: para cada métrica con $M < 7$, diseñar un "gemelo comunicativo" en lenguaje de negocio.
 - **I $\leftrightarrow$ T:** Las métricas más independientes (timestamp externo de notificación, resultado de auditoría externa) son a menudo menos oportunas (auditorías anuales, no en tiempo real). El cuadro de mando necesita una combinación de métricas de alta frecuencia (aunque con I medio) y métricas de validación periódica (alta I, menor T).
- P $\leftrightarrow$ C:** Las pocas métricas con alta capacidad predictiva (ϵ , DIR, D-M4) son las más costosas de recoger (modelos ML, pentesting, análisis de equidad). El cuadro de mando debe incluir al menos 2–3 métricas predictivas de alta calidad para no ser exclusivamente reactivo, aunque su coste sea mayor.
- M $\leftrightarrow$ G:** Las métricas más técnicamente precisas (ϵ de privacidad diferencial, FAR biométrica) son las menos comprensibles para directivos no técnicos. Solución: para cada métrica con $M < 7$, diseñar un "gemelo comunicativo" en lenguaje de negocio.
- I $\leftrightarrow$ T:** Las métricas más independientes (timestamp externo de notificación, resultado de auditoría externa) son a menudo menos oportunas (auditorías anuales, no en tiempo real). El cuadro de mando necesita una combinación de métricas de alta frecuencia (aunque con I medio) y métricas de validación periódica (alta I, menor T).

TABLA DE ACCIONES DE MEJORA POR CRITERIO DÉBIL

Criterio débil principal	Métricas afectadas	Acción de mejora recomendada
P (Predictivo)	L-M1, L-M3, I-M4, NC-M2, NC-M3, DD-M4, U-M1	Añadir indicadores adelantados (leading KPIs): N.º proyectos sin EIPD solicitada, N.º proveedores nuevos sin DPA, tasa de nuevos campos de datos no clasificados
M (Meaningful)	I-M5 (ϵ), IN-M3 (DIR)	Diseñar "gemelo comunicativo" para cada métrica técnica: traducir ϵ y DIR a lenguaje de riesgo de negocio comprensible por el Consejo
C (Cheap)	I-M5 (ϵ), IN-M3 (DIR), D-M4 (side-channel)	Priorizar estas métricas solo para sistemas de alto riesgo (IA en RR.HH., scoring financiero, biometría); usar métodos aproximados de bajo coste para el resto
G (Genuino)	L-M3 (ICAV)	Complementar con pruebas de penetración de re-identificación periódicas para validar que el ICAV refleja el riesgo real

Evaluación PRAGMATIC realizada conforme a la metodología de Brotby & Hinson (2013), adaptada al contexto LINDDUN/LIINE4DU. Las puntuaciones son indicativas y deben ajustarse al contexto específico de cada organización. Versión 1.0 — Abril 2026.